AI ADOPTION AUDIT · MANAGEMENT REPORT

multi-agent-admin

A well-built Claude Code setup: skills, hooks and docs.
But everything reached `master` in one direct commit, with no CI.

Findings from the audit of the multi-agent-admin repo and the practice questionnaire, with a prioritised action plan.

AI MATURITY SCORE · SCALE 1–5



The way forward: Protect `master` and land every change as a PR, add PR CI, turn on the agent sandbox with a network allowlist, and add licence and regulatory sections to the AI policy.

1	1	1	3
Repo audited	Questionnaire respondent	Critical findings	High findings

Audit date 15 Oct 2026
Report prepared 15 Oct 2026

EXECUTIVE SUMMARY

Strong agent setup, with no review path to `master` yet

Instructions, skills, hooks and docs are in place: CLAUDE.md imports AGENTS.md, 5 skills, tested hooks and gitleaks. The biggest risk is that all code and AI config reached `master` as one 21,203-line direct commit, with no CI and no verified branch protection. The biggest opportunity is correcting AGENTS.md and the stale docs.

AI maturity score	Projected	Critical findings	Practice Score	Merged PRs on master
4.00 / 5	**4.83** / 5	**1**	**63** / 100	**0**
Managed	Optimized if all audit changes are done	Plus 3 high	Advanced · one respondent	one 21,203-line direct commit

STRONGEST AREA

Skills, hooks, context

5 spec-compliant skills, tested PreToolUse/PostToolUse/Stop hooks and 54 always-loaded lines: Skills, Guardrails and Context all score 5.

BIGGEST BLIND SPOT

Git and review

AI config and all code arrived in direct commit 5aace9f on `master`; no PRs, no CI. Git & Review is capped at 2.

FIRST THING TO FIX

Protect master

A GitHub ruleset on `master`: PR required, 1 approval, required checks, no bypass; land every change as a PR.

WHAT EACH SOURCE SAYS

AI audit 1 repo	Score 4.0 / 5 (80%) · Managed · 1 critical / 3 high · projected 4.83 (Optimized)
Questionnaire 1 respondent	Claude Code; agent edits files in the repo · Practice Score 63 (Advanced) · 5/6 scenarios right · no claim contradicted

TWO-SOURCE COMPARISON

The sources agree; the gaps are review practice and agent briefs

All 7 themes are **Aligned**. No claim is contradicted, but the verification scenario is answered right while `master` has no PR or CI, and the prompt exercise misses 4 of 5 elements.

7 Aligned

Levels: Strong · Partial · Weak · audit scores out of 5

THEME	AI AUDIT · REPO EVIDENCE	QUESTIONNAIRE · KNOWLEDGE AND CLAIMS	VERDICT
Adoption & usage	Partial Committed Claude Code setup; 0 AI-attributed commits	Partial Claude Code, agent edits files; Q9 graded 1 (no outcome)	Aligned
Instruction files & project map	Strong 4.50 Instructions 4, Context 5: AGENTS.md import, scoped rules, 54 lines	Strong Works from shared docs, skills, guardrails (X1 consistent); Q5 right	Aligned
Knowledge base & docs	Strong 4.00 Docs 4: architecture, ADRs, clone-to-green; stale CI and DB claims	Partial Points the agent to the auto-logout API (E2); Q10 graded 1	Aligned
Skills, commands & MCP	Strong 5.00 Skills 5: 5 skills with verify steps; MCP N/A, none adopted	Strong MCP vetting scenario right (Q6)	Aligned
Guardrails, permissions & secrets	Strong 4.50 Guardrails 5, Permissions 4: tested hooks, deny rules; no sandbox (High)	Partial Permissions scenario right (Q3); prompt injection missed (Q4)	Aligned hook blocks curl | sh
Verification & review	Weak 2.50 Verification 3, Git & Review 2: direct commit to `master` (Critical), no CI	Partial Q7 right; no claim on tests before merge; prompt asks for no test (E5)	Aligned knowledge vs practice
Learning loop & governance	Partial 3.50 Observability 4, Governance 3: AI_LOG.md; no licence or regulatory mapping (High)	Strong Q11 graded 3: switched to HTML-first; no rule added (X3 no claim)	Aligned

KNOWLEDGE VS PRACTICE

The respondent knows most practices; review is the one not in place

5 of 6 scenarios right. The repo already backs most of them; the missing piece is PRs and CI on `master`.

5/6 scenarios answered right. The one miss: prompt injection (Q4).

PRACTICE (SCENARIO)	RESPONDENT KNOWS	REPO EVIDENCE
Allow specific commands, keep deny rules (Q3)	✓ **Right**	⚠ **Partly in place.** Narrow allow/ask/deny, bypass disabled; no sandbox or egress limit
Text in files is data, not instructions (Q4)	✗ **Missed**	✓ **In place.** `guard-bash.mjs` blocks curl | sh; AGENTS.md hard rule 3
Read the diff; check no test was weakened (Q7)	✓ **Right**	✗ **Not in place.** Direct commit 5aace9f to `master`; no PRs, no CI
Plan first; lasting rules in the instruction file (Q2, Q5)	✓ **Right**	✓ **In place.** Plan mode in CLAUDE.md:5; scoped rules in `.claude/rules/`

Why review lags: setup, and briefs

What the prompt exercise and the flags show

✗ **No review path to master**
No ruleset, no PRs and no CI, so nothing enforces the diff check the respondent knows.

⚠ **Brief has 1 of 5 elements**
Points to the auto-logout API, but no goal, no investigate-first, no constraints, no test.

✓ **No flags; skills encode it**
No questionnaire flags; `/fix-issue` already encodes a reproduce-first, done-check brief.

Prompt exercise: E1 goal and done-criteria · E2 context · E3 investigate first · E4 constraints · E5 verification

Shared setup and briefs, not training. Protect `master`, add PR CI, and brief the agent through `/fix-issue`.

WHERE THE SOURCES DISAGREE

No claim is contradicted; two gaps between knowledge and practice

The first carries the most risk.

	TOPIC	THE QUESTIONNAIRE SAYS	THE EVIDENCE SHOWS	SO WHAT
1	**Diff check before PR**	Read the diff, run the tests, check no test was weakened (Q7, right).	All code and AI config reached `master` as one 21,203-line direct commit 5aace9f; no PRs, no CI, branch protection unverified.	**Nothing enforces review.** Action 1
2	**Permissions setup**	Allow specific commands, keep deny rules (Q3, right).	Narrow allow/ask/deny in `.claude/settings.json`, but no sandbox and no network egress limit for agent shells.	**Agent shells reach any host.** Action 3
3	**Prompt injection**	Ask the agent whether a README command looks safe (Q4, missed).	The repo already blocks it: `guard-bash.mjs` stops curl | sh, and AGENTS.md hard rule 3 treats text as data.	**Awareness gap; hook covers it.** Action 3

REPOSITORY SCORECARD

Scores 4.0 (Managed) now; all changes would take it to 4.83

Skills, Guardrails and Context score 5. Git & Review is capped at 2 by the direct commit, and Verification and Governance score 3 with no CI.

Audit score by theme

Out of 5; score per theme, coloured by the level the report assigns



Score today and projected

Out of 5 · dark dot today, light dot projected if all audit changes are done

REPO	1	2	3	4	5	CRIT.	HIGH
multi-agent-admin Managed → Optimized				**4.00** ● — ● 4.83		1	3

WEAKEST AREAS AND WHAT ALREADY WORKS

- Scored ≤ 2: Git & Review Workflow **2.00**
- Skills 5: 5 spec-compliant skills with verify steps; `/open-pr` manual-only
- Guardrails 5: tested PreToolUse/PostToolUse/Stop hooks and husky gitleaks
- Context 5: 54 always-loaded lines, path-scoped rules, model per subagent

SECURITY FINDINGS

1 critical finding: everything reached `master` with no PR

Critical: AI config and code reaching the default branch by direct commit, with no PR (fix now). High: An important control is missing, e.g. no sandbox, no CI, no licence or regulatory guidance (fix soon).

FINDING	multi-agent-admin	Fixed by action
Critical · fix now		
AI config and all code reached `master` by direct commit, no PR	1	1
High · fix soon		
No CI: AI config and hooks never validated on PRs	2	2
No sandbox, no network egress limit for agent shells	3	3
No licence/IP guidance; no regulatory mapping for sick-leave data	4	4
Total per repo · critical / high	**1 / 3**	**1 / 3**

Each square is one audit finding; the rows add up to the audit's stated totals (1 critical, 3 high).

QUESTIONNAIRE RESULTS

One respondent: strong on scenarios, weaker on briefs and write-ups

One person's answers, graded against fixed anchors. Scenarios 5/6 and all claims match the audit; the prompt exercise has 1 of 5 elements and two written answers are graded 1.

63 / 100
Practice Score
only 'matches the audit' differs between repos

Advanced
Level
self-administered; not an employee evaluation

5/6
Scenarios right

1 / 5
Prompt exercise elements

Score parts

Written answers	22.2 / 40
Prompt exercise	3 / 15
Scenarios	20 / 24
Work mode	8 / 11

Role: Full-stack · **Experience:** 5–8 yrs · **Work mode:** d) agent edits files

⚠ Q10 describes project setup, not a task-to-merge flow, and names no check before merge.

Scenarios

Q2	planning a large change	Context & Cost	Right
Q3	permissions setup	Guardrails & Hooks / Permissions & Secrets	Right
Q4	prompt injection	Permissions & Secrets	Missed
Q5	long-session context	Context & Cost	Right
Q6	MCP vetting	MCP Servers & Plugins	Right
Q7	verifying 'done'	Verification & Testing / Git & Review Workflow	Right

Written answers (graded 0–3)

Q9 a concrete win	1 / 3
Q10 how the team works	1 / 3
Q11 after a mistake	3 / 3

Says vs found (claims checked against each repo's audit)

	CONSISTENT	CONTRADICTED	NOT CHECKABLE	NO CLAIM	CONTRADICTED IN
X1 Works from a shared instruction file, rules or skills	1	0	0	0	—
X2 Tests or CI run before merge	0	0	0	1	—
X3 A rule, hook or check was added after a mistake	0	0	0	1	—

Flags (per report): none

RECOMMENDED ACTIONS

Ten actions: protect `master`, add CI, sandbox, policy first

Actions 1–4 close the critical finding and all 3 high findings; 5–10 lift the remaining scores.

#	ACTION	WHAT IT INVOLVES	WHAT IT FIXES	EFFORT
CLOSE THE CRITICAL AND HIGH				
1	**Protect master, land via PR**	Ruleset on `master`: PR, 1 approval, code-owner review, required checks, no force-push or bypass; every change as a PR with the Co-authored-by trailer.	1 Critical Verification & review (Aligned)	Quick
2	**PR CI**	`.github/workflows/ci.yml` on pull_request: typecheck, lint, test incl. hooks, build, gitleaks, dependency-review, CodeQL; add Dependabot.	1 High Verification & review (Aligned)	Short
3	**Agent sandbox**	`.claude/settings.json`: enable `sandbox` with a `network.allowedDomains` list (npm registry, GitHub).	1 High	Quick
4	**Complete the AI policy**	`docs/ai-policy.md`: licence/IP rules, regulatory mapping for employee and sick-leave data, review cadence, approved accounts, transcript retention.	1 High	Quick
CORRECT DOCS, OBSERVE				
5	**Correct AGENTS.md**	Add `npm run build` under Commands; mark "Express 5 API" as planned, since no express dependency exists.		Quick
6	**Fix stale docs**	CI and DB claims in `docs/mcp-inventory.md`, `docs/architecture.md`, `docs/ai-policy.md` (branch is `master`); add a key-versions line.		Quick
7	**Guard instruction files**	Human edit of `guard-files.mjs`: add AGENTS.md, CLAUDE.md, `.claude/rules/`, `.claude/skills/`, `.claude/agents/` to HUMAN_ONLY.		Quick
8	**Telemetry and spend**	Document the OTEL telemetry exporter with an owner, spend tracking and spike alerts in `docs/ai-policy.md`.		Short
TESTING AND HYGIENE				
9	**Playwright e2e for web**	Add `web/e2e/` and a `test:e2e` script, and run it in CI.		Short
10	**Skill tools, sessions, backup**	`allowed-tools` on fix-issue, new-feature, change-policy; session hygiene in CONTRIBUTING.md; name a backup AI owner.	Prompt exercise E1, E3–E5	Quick

Chips count finding types (rows on the security page) that the action closes.

ROADMAP & DECISIONS

One hardening week closes every critical and high finding

STEP 1 · HARDENING WEEK

Ruleset, CI, sandbox, policy

Protect `master`; PR CI; agent sandbox; licence and regulatory sections.

1 2 3 4

→

STEP 2

Correct docs and observe

Fix AGENTS.md and stale docs; guard instruction files; telemetry.

5 6 7 8

→

STEP 3 · THEN

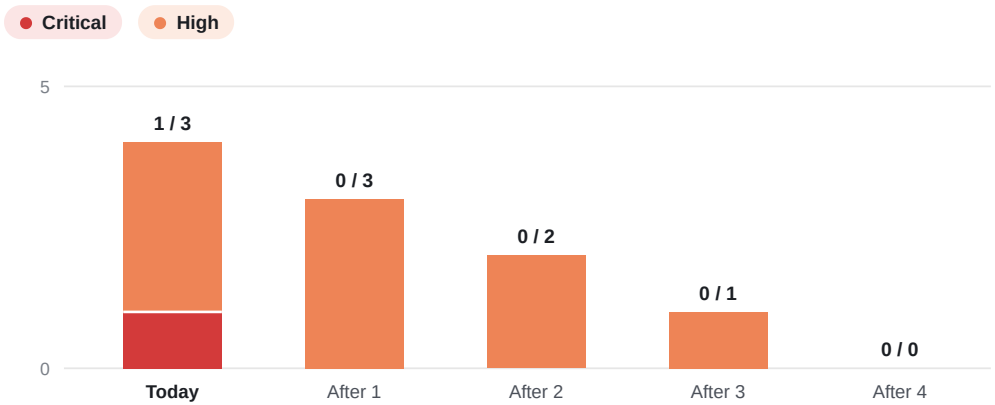
Testing and hygiene

Playwright e2e; skill tools, session hygiene, backup owner.

9 10

Open findings as each action is completed

Critical / high finding types left open (rows on the security page), using the action mapping on the actions page



1 → 0

critical finding types after step 1 (actions 1, 2, 3, 4)

4.00 → 4.83

projected score if all audit changes are done

DECISIONS NEEDED FROM MANAGEMENT

1. **Require PRs on master**
   All code and AI config arrived by one direct commit; no PRs.
2. **Fund PR CI and scans**
   No workflow exists; `docs/ai-policy.md:67` describes one that doesn't.
3. **Set licence and data rules**
   No licence/IP or regulatory mapping for sick-leave data.
4. **Name a backup AI owner**
   Its stated deadline is today; needed once a 2nd contributor joins.

The chart counts finding types, not per-repo instances; the audit states 1 critical and 3 high.

ABOUT THIS REPORT

Sources, definitions and limits

SOURCES

1 audit report (multi-agent-admin; Claude Code · claude-opus-5-5 · model check pinned).

Questionnaire results from 1 respondent (one answers file reused for every repo).

Full detail: `multi-agent-admin-2026-10-15.md`, the Markdown report this page set summarises.

> **Confidentiality.** No names or emails. The questionnaire is self-administered: one person's answers graded against fixed anchors, a practice indicator, not an employee evaluation. This report describes security findings; share it internally only. The questionnaire sections describe one person's answers.

READING GUIDE

Critical	AI config and code reaching the default branch by direct commit, with no PR. Fix now.
High	An important control is missing, e.g. no sandbox, no CI, no licence or regulatory guidance. Fix soon.
Aligned	The sources agree, whether the picture they give is good or bad.
Overstated	The questionnaire claims or knows more than the repos show.
Understated	The questionnaire is lower than the repos show: an awareness gap.
Mixed	Answers or repos point in different directions.
Single source	Only one source covers the theme.
Strong Partial Weak	Level per source and theme. Audit levels come from the average score (Strong ≥ 3.5, Partial 2.5–3.4, Weak < 2.5), stepped down where a critical finding sits in the theme.

LIMITS OF THIS REPORT

- Branch protection, host secret scanning and required CI checks: `gh` not authenticated.
- Managed org policy, approved org accounts and bot identities: need admin or GitHub app settings.
- Spend tracking and cost spike alerts: need the Anthropic Console or billing owner.
- Transcript retention: needs the vendor data-retention settings.
- AI-split outcome metrics: need issue/PR labels or a metrics dashboard.
- AI-attributed set and PR sample were empty: 0 trailers, no merged PRs.
- History scan covered 1 commit with gitleaks; trufflehog not installed.
- One respondent; the questionnaire describes one person's answers, not an evaluation.